

CARDIAC PATIENT MONITORING SYSTEM

Authorization Matrix — Final Clean Reference

BinX Tech • Backend .NET Internship • Week 4

Purpose	A clear, presentation-ready reference for who is allowed to perform each API operation.
Roles	Admin • Doctor • Patient
Authorization model	Role-Based + Resource/Ownership checks; policy-based rules are reserved for reusable business requirements.

1. Role-Based Authorization Matrix

This table follows the project authorization matrix. ✓ means the role is allowed. ✓* means the role is allowed only after an additional ownership/resource check. ✗ means the role is not allowed.

Resource	Action	Admin	Doctor	Patient
Doctors	View Doctors	✓	✓	✓
Doctors	Create Doctor	✓	✗	✗
Doctors	Update Doctor	✓	✗	✗
Doctors	Delete Doctor	✓	✗	✗
Patients	View Patients	✓	✓*	✓*
Patients	Create Patient	✓	✗	✓
Patients	Update Patient	✓	✓*	✓*
Patients	Delete Patient	✓	✗	✗
Vital Signs	View Vital Signs	✓	✓*	✓*
Vital Signs	Create Vital Sign	✓	✓*	✓*
Vital Signs	Update Vital Sign	✓	✓*	✗
Vital Signs	Delete Vital Sign	✓	✗	✗
Medications	View Medications	✓	✓	✓
Medications	Create Medication	✓	✓	✗
Medications	Update Medication	✓	✓	✗
Medications	Delete Medication	✓	✗	✗
Patient Medications	View Patient Medications	✓	✓*	✓*
Patient Medications	Create Patient Medication	✓	✓*	✗
Patient Medications	Update Patient Medication	✓	✓*	✗
Patient Medications	Delete Patient Medication	✓	✗	✗
Appointments	View Appointments	✓	✓*	✓*
Appointments	Create Appointment	✓	✓*	✓*
Appointments	Update Appointment	✓	✓*	✓*
Appointments	Delete Appointment	✓	✗	✗

Important correction: Patient and Doctor do not have permission to create, update, or delete Doctor records. The tested cross-role scenario explicitly expects Create Doctor = Admin PASS / Doctor 403 / Patient 403, and Delete Doctor follows the same rule.

2. Ownership Rules — The Part That Makes the Matrix Real

Doctor → Patient	Having the Doctor role alone is not enough for patient-related resources. The doctor may access an assigned patient, but an unrelated patient must be rejected when the ownership/resource check is active.
Patient → Own Data	A patient may access their own profile and health-related resources. A patient's request for another patient's protected health data must be rejected when the ownership check is active.

3. Authorization Levels

Level	When it is used	Example
1 — Role-Based	The rule depends only on the user's role.	[Authorize(Roles = "Doctor")]
2 — Policy-Based	A reusable business requirement.	Age ≥ 18 / AdultOnly
3 — Resource-Based	Permission depends on the relationship to a specific resource.	Doctor → assigned Patient; Patient → own data

4. HTTP Authorization Outcomes

Situation	Expected result
No JWT / invalid authentication credentials	401 Unauthorized
Valid JWT + insufficient role	403 Forbidden
Valid Doctor JWT + unrelated patient resource	403 Forbidden
Valid Patient JWT + another patient's protected resource	403 Forbidden

5. Verified Testing Reference

Test	Expected / observed authorization result
Create Doctor	Admin → PASS (201); Doctor → 403; Patient → 403
Delete Doctor	Admin → PASS; Doctor → 403; Patient → 403
Delete Patient	Admin → PASS; Doctor → 403; Patient → 403
Create Medication	Admin → PASS; Doctor → PASS; Patient → 403
Update Medication	Admin → PASS; Doctor → PASS; Patient → 403
Delete Medication	Admin → PASS; Doctor → 403; Patient → 403
Delete Vital Sign	Admin → PASS; Doctor → 403; Patient → 403
Delete Patient Medication	Admin → PASS; Doctor → 403; Patient → 403
Delete Appointment	Admin → PASS; Doctor → 403; Patient → 403

Important implementation note: The authorization matrix is the design reference, while the End-to-End Test Scenario records expected authorization outcomes. Ownership-dependent cases should be treated as a GAP/FAIL if the ownership check has not yet been implemented; do not change the expected rule just to match an incomplete implementation.

6. Final Takeaway

Admin is the administrative role. Doctor handles clinical operations and patient-related resources subject to ownership. Patient is restricted to their own data and explicitly allowed patient actions. Most importantly: being authenticated does not mean being authorized — a valid JWT with insufficient permission results in 403 Forbidden.